

Chapitre I : Protocoles sécurisés : généralités

Dans ce premier chapitre, nous introduisons les concepts élémentaires dans les protocoles sécurisés. Nous commençons par décrire les dimensions de sécurité (l'authentification, la confidentialité des données, l'intégrité des données, la non répudiation, le contrôle d'accès et la disponibilité). Ensuite, nous présentons les différents types de vulnérabilité et d'attaque. Après avoir discuté les ennuis causés par les attaques, nous détaillons les différents mécanismes cryptographiques.

1.1. Propriétés de la sécurité

L'UIT (Union internationale des télécommunications) a défini un ensemble large de dimension de sécurité qui comprend: l'authentification, la confidentialité des données, l'intégrité des données, la non-répudiation, le contrôle d'accès et la disponibilité (ITU-T, 2003).

❖ **L'authentification**: elle est le processus de sécurité qui vérifie l'identité d'une entité demandant l'accès aux ressources ou applications du système. L'entité peut être une personne ou non-personne comme routeur, pare-feu, application, bases de données ou un autre composant du système. La figure suivante montre la décomposition d'authentification.

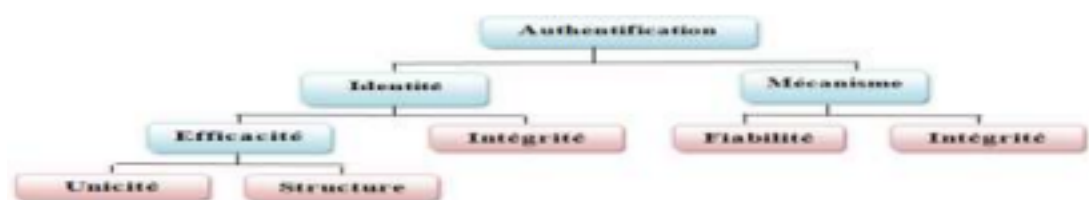


Figure 1. 1 La décomposition d'authentification

Il existe de nombreux mécanismes ou facteurs d'authentification:

- **Ce que je sais**: par exemple, un mot de passe;
- **Ce que je sais faire**: une signature manuscrite sur écran tactile/digital;
- **Ce que je suis**: une caractéristique physique comme une empreinte digitale;
- **Ce que je possède**: une carte à puce par exemple.

❖ **La confidentialité**: la confidentialité est une propriété de sécurité qui stipule qu'une information ne peut être utilisée ou lue que par sa destination et non par

Chapitre I : Protocoles sécurisés : généralités

une autre entité. Assurer la confidentialité des données implique l'implémentation des techniques empêchant toute délibération ou divulgation de l'information à des utilisateurs non autorisés. Ces derniers sont appelés les mécanismes de chiffrement qui sont détaillés dans la section (1.3).

- ❖ **L'intégrité:** l'intégrité est un service de sécurité qui assure que les informations transmises entre la source et la destination n'ont pas été altérées. Garantir l'intégrité des données implique la prévention et la détection de la modification, l'ajout ou la suppression des informations.
- ❖ **La non-répudiation:** c'est l'ensemble des contrôles nécessaires pour prévenir la répudiation. Typiquement, la non-répudiation se réfère à la capacité d'empêcher une personne ou une entité ayant effectué des opérations sur des données de pouvoir nier l'avoir fait.
- ❖ **Le contrôle d'accès:** c'est l'ensemble des politiques de sécurité nécessaires pour prévenir l'utilisation non autorisée d'une ressource du réseau. Le contrôle d'accès consiste à assurer que seules les personnes ou les entités autorisées peuvent accéder aux éléments du réseau, aux services, aux flux d'informations et aux applications.
- ❖ **La disponibilité:** la disponibilité est la capacité d'assurer que les utilisateurs ont un accès rapide et continu aux éléments du réseau, aux informations, aux services et aux applications. Garantir la disponibilité des systèmes, implique l'implémentation des techniques empêchant toute tentative de déni de service.

1.2. Vulnérabilité, Attaques

Une vulnérabilité est une faiblesse identifiée dans un système contrôlé, où les mécanismes de contrôle ne sont pas présents ou ne sont plus efficaces (ISO/IEC 27000, 2009).

Une attaque est un acte qui exploite une faille pour compromettre un système

contrôlé. Il est réalisé par un attaquant qui détruit, modifie, expose, vole ou obtient un accès non autorisé aux informations, aux services, aux flux d'informations et aux

Chapitre I : Protocoles sécurisés : généralités

applications d'une organisation. Comme l'illustre la Figure 1.1; on distingue deux types d'attaques, et chacune d'entre elles se subdivise en plusieurs catégories:

- ❖ **L'attaque passive:** ce type d'attaque consiste à analyser et surveiller les communications non protégées, décrypter le trafic au cryptage faible et capturer les informations d'authentification (comme les mots de passe). L'attaque peut entraîner la divulgation des informations à un attaquant sans l'autorisation ou la connaissance de l'utilisateur. Les exemples des attaques passives incluent la divulgation de renseignements personnels tels que des numéros de carte de crédit, mot de passe des E-mails et les dossiers médicaux (Van Quang, 2005; Cole et al., 2005).
- ❖ **L'attaque active:** ce type d'attaque a pour but de contourner ou de briser les fonctions de protection, voler ou modifier les informations, et introduire un code malveillant. L'attaque active peut entraîner la divulgation ou la diffusion des fichiers de données, le déni de service, ou la modification de données (Van Quang, 2005; Cole et al., 2005).

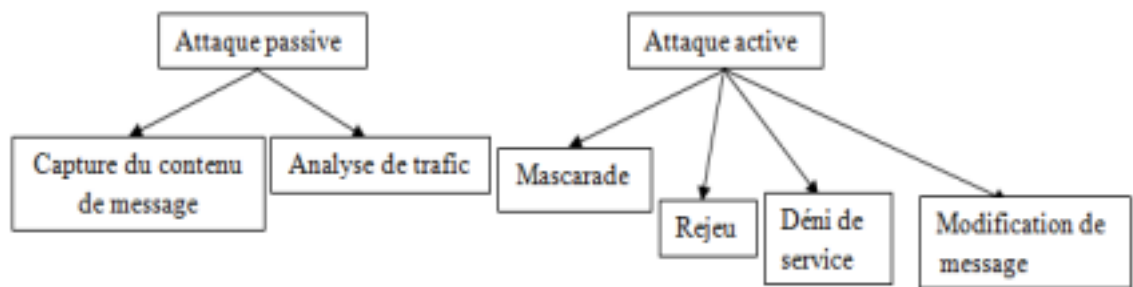


Figure 1.2 Différents types d'attaques (Van Quang, 2005)

Les instanciations spécifiques de ces types d'attaques sont discutées dans ce qui suit:

- Le déni de service (DoS): l'attaquant envoie un grand nombre de connexions ou des demandes d'informations, afin de rendre la machine cible surchargée pour qu'elle ne puisse pas répondre aux demandes légitimes de service (voir Figure 1.3). La machine cible peut se bloquer ou simplement devenir incapable de remplir les fonctions ordinaires (Michael and Herbert, 2009).

Chapitre I : Protocoles sécurisés : généralités

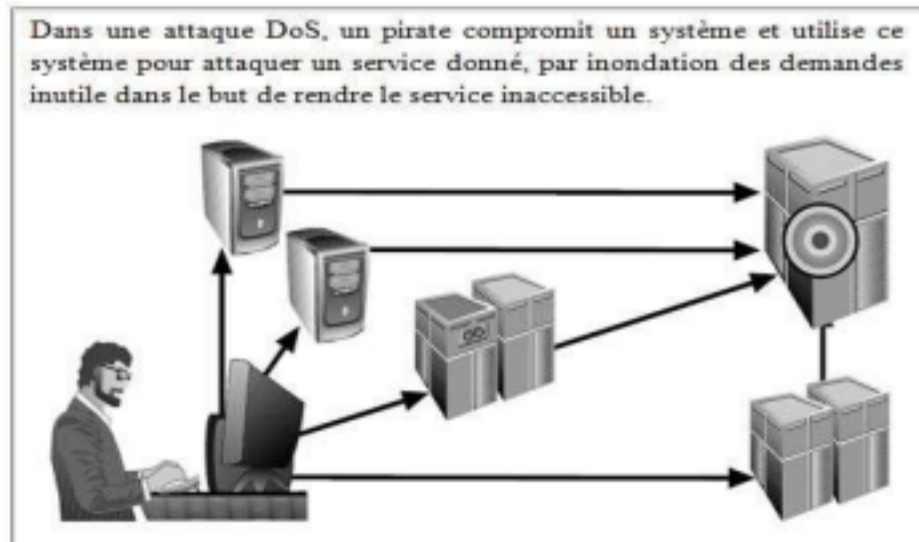


Figure 1.3 Attaque de déni de service (Michael and Herbert, 2009) □

L'attaque de l'homme du milieu (HDM) ou man-in-the-middle (MITM): se produit quand un attaquant (Carol) se positionne entre les deux entités de communications (Alice et Bob) dans le but d'espionner, modifier, supprimer, re-router, ajouter, forger, ou détourner des données échangées entre eux (Michael and Herbert, 2009).

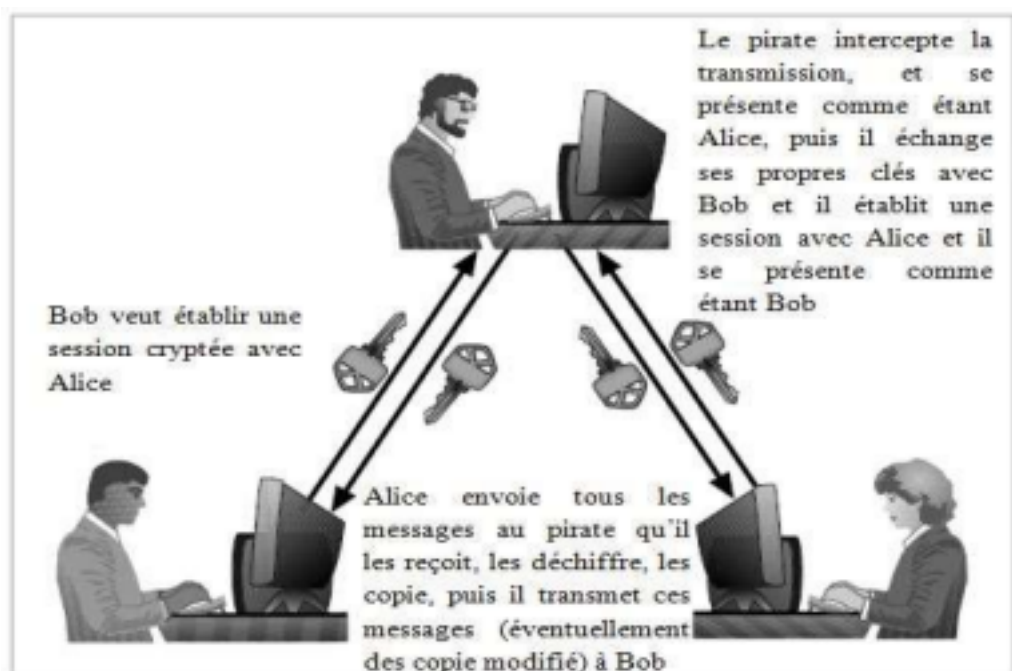


Figure 1.4 Attaque de l'homme du milieu (Michael and Herbert, 2009) □

L'attaque par rejeu ou replay attack : l'attaquant intercepte des paquets de données et les rejoue dans le but d'usurper l'identité ou les droits d'un

Chapitre I : Protocoles sécurisés : généralités

utilisateur légitime. Un attaquant (Carol) met sur écoute les échanges transmis entre la source (Alice) et la destination (Bob), puis il utilise les messages enregistrés pour communiquer avec Alice et Bob (Cole et al., 2005).

- L'attaque par réflexion: cette attaque consiste à utiliser l'IP spoofing et l'ICMP afin de saturer un réseau cible avec le trafic, en lançant une attaque DoS. Elle se compose de trois éléments : le site source, le site de rebond, et le site cible. L'attaquant (le site source) envoie un paquet de ping usurpé à l'adresse de diffusion d'un grand réseau (le site de rebond). Ce paquet modifié contient l'adresse du site cible. Cela provoque le site de rebond pour diffuser les fausses informations pour tous les appareils sur son réseau local. Donc tous ces dispositifs répondent avec une réponse de type « replay » au système cible, qui sera saturé (Cole et al., 2005).

1.3. Mécanisme de sécurité cryptographique

La cryptographie est un ensemble de techniques permettant d'assurer les dimensions de sécurité par l'utilisation des méthodes de chiffrement. Le chiffrement permet de transformer le texte clair en un texte chiffré à l'aide d'un algorithme de chiffrement et d'une clé (voir Figure 1.5). Le déchiffrement permet de transformer le texte chiffré en texte clair identique à celui d'origine à l'aide d'un algorithme de déchiffrement et une clé (Baudet, 2007 ; Lafourcade, 2006).

Clé Clé

Message original Message chiffré Message original Chiffrement Déchiffrement

Figure 1.5 Processus général de cryptage

Les algorithmes de chiffrement et de déchiffrement sont basés sur des problèmes mathématiques difficiles à résoudre. De plus, il est difficile de déchiffrer le message chiffré sans connaître la clé secrète. En général, les méthodes cryptographiques sont divisées en deux grandes catégories: la cryptographie symétrique dite à clé secrète et

Chapitre I : Protocoles sécurisés : généralités

cryptographies utilisent une combinaison hybride des algorithmes symétriques et asymétriques.

1.3.1. Chiffrement symétrique

Dans cette méthode de chiffrement, la clé utilisée pour le chiffrement et le déchiffrement du message est la même. Le schéma suivant illustre le fonctionnement de la méthode du chiffrement symétrique (Baudet, 2007; Lafourcade, 2006).

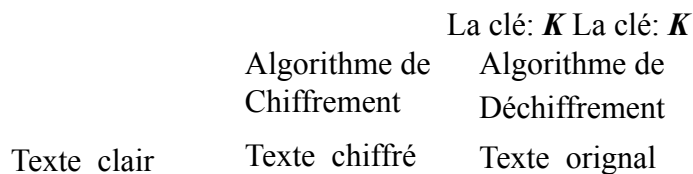


Figure 1.6 Chiffrement symétrique

Les méthodes de chiffrement symétrique utilisent des opérateurs mathématiques tels que la substitution et la transposition qui peuvent être programmées dans des algorithmes de calcul extrêmement rapides afin que le processus de chiffrement et de déchiffrement soit exécuté rapidement même dans de petits ordinateurs. L'inconvénient majeur de cette méthode de chiffrement est qu'il faut partager une clé secrète entre l'initiateur et le répondeur en toute sécurité. Cependant, si l'une des copies de la clé tombe dans de mauvaises mains, les messages peuvent être déchiffrés par d'autres personnes et l'initiateur et le répondeur prévus ne vont pas être au courant que le message a été intercepté. Il existe plusieurs algorithmes populaires de chiffrement symétriques. Parmi ces algorithmes, nous présentons DES (Data Encryption Standard), 3DES (Triple DES) et AES (Advanced Encryption Standard).

1.3.2 Chiffrement asymétrique

Contrairement au chiffrement symétrique qui utilise la même clé pour le chiffrement et le déchiffrement, le chiffrement asymétrique utilise deux clés différentes mais liées (clé publique et clé privée) ; l'une des clés est utilisée pour chiffrer et l'autre pour déchiffrer le message. Si la clé A est utilisée pour chiffrer un message, seule la clé B

peut le déchiffrer, et si la clé B est utilisée pour chiffrer un message seule la clé A peut le déchiffrer. Le but principal de chiffrement asymétrique est de fournir des

Chapitre I : Protocoles sécurisés : généralités

solutions élégantes aux problèmes de partage de la clé secrète et la vérification d'identité. Le schéma de chiffrement asymétrique est illustré dans la Figure 1.6.

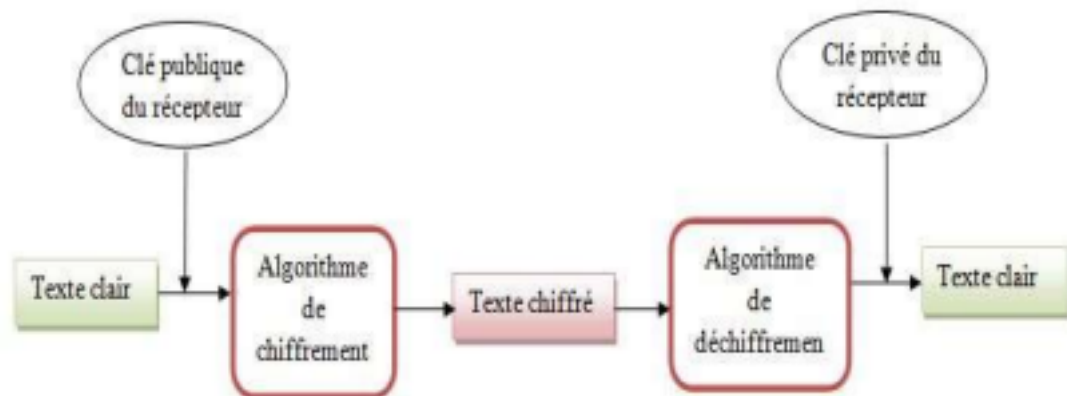


Figure 1.6 Chiffrement asymétrique

Nous détaillons ci-dessous les différentes méthodes de chiffrement asymétrique le plus utilisé ces dernières années.

1.3.2.1 Diffie-Hellman

Diffie-Hellman est le premier algorithme publié en 1976 par Whitfield Diffie et Martin E. Hellman de l'université de Stanford. Le but de cet algorithme est de résoudre le problème d'échange de la clé secrète entre deux communicants qui ne sont jamais rencontrés. Cet algorithme est basé sur deux problèmes, le premier est le DLP (Discrete Logarithm Problem) et le deuxième, le DHP (Diffie-Hellman Problem) (Guillot, 2013; Mansour, 2013).

- ❖ Le problème du logarithme discret (DLP): est une application réciproque de l'exponentiation, C'est l'analogue du logarithme qui est la réciproque de l'exponentielle. Nous présentons ci-dessous le DLP.

Instance: Soient G un groupe fini d'ordre n et $g \in G$. Etant donné un élément $\beta \in G$,

Question: trouver le nombre entier a où $0 \leq a \leq n-1$, de telle sorte que $g^a = \beta$?

- ❖ Le DHP (Diffie-Hellman Problem): La motivation de proposer ce problème mathématique par Diffie et Hellman est parce qu'il existe de nombreux systèmes

Chapitre I : Protocoles sécurisés : généralités

de sécurité utilisant des opérations mathématiques qui sont rapides à calculer, mais difficiles à inverser. Le problème Diffie-Hellman est représenté de façon informelle comme suit. Il est très difficile de calculer g^{ab} par la connaissance de g , g^a et g^b (Guillot, 2013; Mansour, 2013).

Étant donné un élément g et les valeurs de g^a et g^b , qu'elle est la valeur de g^{ab} ? a et b sont des nombres entiers aléatoires et g est un générateur d'un groupe fini G .

Le protocole d'échange de clé Diffie-Hellman basé sur DLP et DHL sert à partager une clé secrète entre deux communicantes via un canal non sûr. Cette clé secrète peut être utilisée dans un procédé de chiffrement symétrique. La description de protocole Diffie-Hellman à clé publique est illustrée dans la figure suivante.

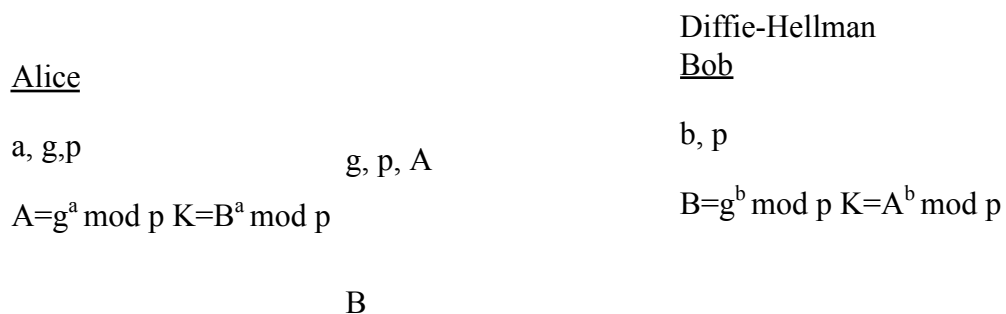


Figure 1.7 Protocole

Les deux interlocuteurs (Alice et bob) partagent deux paramètres non secrets : un groupe fini cyclique G d'ordre p et un générateur g de G . Ensuite, chacun d'eux choisit un nombre secret de façon aléatoire (a et b respectivement), puis Alice et Bob calculent et échangent entre eux les valeurs publiques A et B tels que: $A = g^a \bmod p$ et $B = g^b \bmod p$. Alice et Bob, maintenant, peuvent calculer la clé secrète K telle que $K = g^{ab} \bmod p$.

1.3.2.2 Signature numérique

La signature numérique est une méthode qui sert à prouver l'identité de l'expéditeur d'un message, garantir l'intégrité des données et assurer la non-répudiation afin d'empêcher l'expéditeur de prétendre qu'il n'a pas envoyé les informations. Le schéma de signature numérique est basé sur la clé privée et la fonction de hachage.

Page 14

Chapitre I : Protocoles sécurisés : généralités

Les fonctions de hachage ou les fonctions à sens unique, sont la quatrième primitive cryptographique. Une fonction de hachage est un algorithme qui prend en entrée un message de taille quelconque et applique un ensemble de transformations pour qu'il revoie en sortie un texte de taille fixe qui varie selon l'algorithme appliqué (128 bits pour MD5 et 160 bits pour SHA-1). Cette sortie est appelée le condensé, valeur de hachage ou résumé de message. Une fonction de hachage devrait satisfaire les quatre propriétés suivantes (Guillot, 2013; Mansour, 2013; Peyrin, 2008; Thuillet, 2012):

- ❖ facilité de calculer l'empreinte du message;
- ❖ impossible de reconstruire un message d'un condensé donné;
- ❖ impossible de trouver deux messages différents avec le même condensé; ❖ La taille du condensé (par une fonction de hachage donnée) est toujours la même (indépendamment de la longueur du message initial).

Pour signer un document, on devrait suivre les deux étapes suivantes. La première consiste à calculer le condensé d'un message afin d'assurer que le message ne sera pas altéré. La deuxième étape consiste à générer la signature numérique, le signataire prend le résultat de la première étape qui est le condensé et le chiffre avec sa clé privée. Ensuite, le signataire attache le résultat de chiffrement avec le texte clair et l'envoie au destinataire. La Figure 1.8 illustre le processus de génération de signature (Guillot, 2013; Mansour, 2013; Peyrin, 2008; Thuillet, 2012).

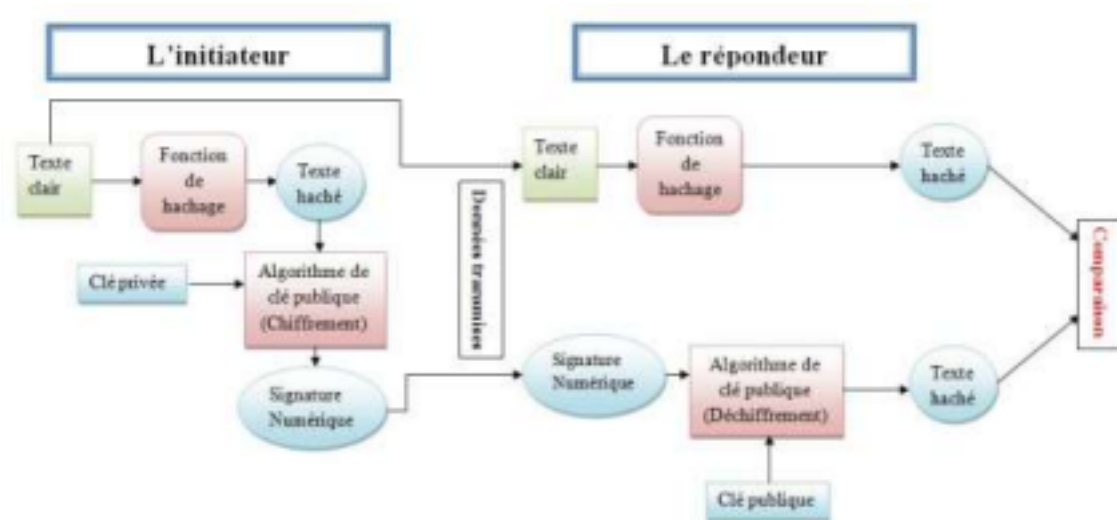


Figure 1.8 Signature numérique

Chapitre I : Protocoles sécurisés : généralités

1.3.2. Etude comparative

Dans cette section nous présentons une comparaison entre les algorithmes de chiffrement symétrique/asymétrique qui sont complémentaire dans les protocoles de sécurité (voir tableau 1.1). Une autre comparaison entre un système asymétrique basé sur RSA et un système asymétrique basé sur les courbes elliptique a été réalisée par NIST. Le tableau 1.2 ci-dessous est publié par le NIST, il définit les forces de sécurité équivalentes entre le RSA, ECC, et des algorithmes de clés symétriques.

Les systèmes de chiffrement	Symétrique	Asymétrique
Les avantages	- La rapidité de calcul - La taille de clé utilisé pour le chiffrement et déchiffrement est courte - Facile à implémenter au niveau matérielle parce qu'il se base sur des opérations simple.	- Aucun canal secret n'est nécessaire pour l'échange des clés publiques. - Nécessite que $2 \times n$ clé pour n entité de communication. - Assure la signature de

		message
Les inconvénients	- Nécessite un canal secret pour envoyer la clé secrète - Il ne garantit pas la propriété de non-répudiation. - Le changement de clé à chaque communication. - Le nombre de clé à gérer égale à $n \times (n-1) / 2$, tel que n est le nombre des entités communicante .	- La taille de clé utilisé pour le chiffrement et le déchiffrement est très grande. - Très lent par apport au chiffrement symétrique - Nécessite des machines puissantes.

Tableau 1.1 Comparaison entre les systèmes de chiffrement symétrique et asymétrique

Page 16

Chapitre I : Protocoles sécurisés : généralités

Symmetric Key Size (m)	Symmetric Algorithm	Hash Algorithm	Elliptic curve modulus	RSA Modulus	Expected Lifetime
56 Bits	DES	-	-	-	Expired
60 Bits	-	MD5	111 Bits	512 Bits	Expired
80 Bits	3DES (2 Key)	SHA-1	160 Bits	1024 Bits	2010
112 Bits	3DES (3 key)	SHA-224	224 Bits	2048 Bits	2030
128 Bits	AES-128	SHA-256	256 Bits	3072 Bits	2031+
192 Bits	AES-192	SHA-384	384 Bits	7680 Bits	2031+
256 Bits	AES-256	SHA-512	512 Bits	15360 Bits	2031+

Tableau 1.2 NIST Crypto Modernization Guidelines (NIST, 2013) Par exemple, l'algorithme AES, avec une taille de clé 128 bits, exige une taille de clé 3072 bits de l'algorithme RSA, mais ne nécessite qu'une taille de clé de 256 bits pour un

algorithme basé sur ECC pour une même force de sécurité.